

VIETNAM NATIONAL UNIVERSITY, HO CHI MINH CITY
UNIVERSITY OF SCIENCE
FACULTY OF INFORMATION TECHNOLOGY



Báo cáo đồ án 2

**Topic: Xây dựng Ứng dụng Web Serverless với Kiến trúc
bảo mật & Tối ưu chi phí**

Course: Nhập môn điện toán đám mây

Prepared by

Nguyễn Minh Tú 23120101

Nguyễn Xuân Duy 23120121

Nguyễn Minh Hiếu 23120124

Ngày 7 tháng 6 năm 2026

Mục lục

I	Giới thiệu	2
1	Phạm vi ứng dụng	2
2	Tóm tắt triển khai	2
3	Thông tin endpoint	3
II	Kiến trúc hệ thống	4
1	Các thành phần chính	5
2	Resource chính	6
3	Luồng request	6
4	Tự mở rộng serverless	7
5	CDN và Origin Access Control	7
6	VPC Endpoint	8
III	Kết quả và bằng chứng	9
1	Bằng chứng bảo mật frontend	9
2	Bằng chứng Cognito và API security	9
3	Bằng chứng networking	10
4	Bằng chứng IAM	10
5	Giám sát	10
6	Chi phí	11
A	Phụ lục	12
1	Checklist bằng chứng bắt buộc	12
2	Prompt GenAI	12
3	Ghi chú source code	12

I Giới thiệu

1 Phạm vi ứng dụng

Ứng dụng Task Manager hỗ trợ các chức năng chính sau:

- Đăng ký và đăng nhập người dùng thông qua Amazon Cognito.
- Tạo, xem, cập nhật và xóa công việc.
- Lưu trữ dữ liệu công việc bền vững trong Amazon DynamoDB.
- Chỉ cho phép người dùng đã xác thực gọi các API `/tasks`.

2 Tóm tắt triển khai

Các điểm triển khai chính của hệ thống:

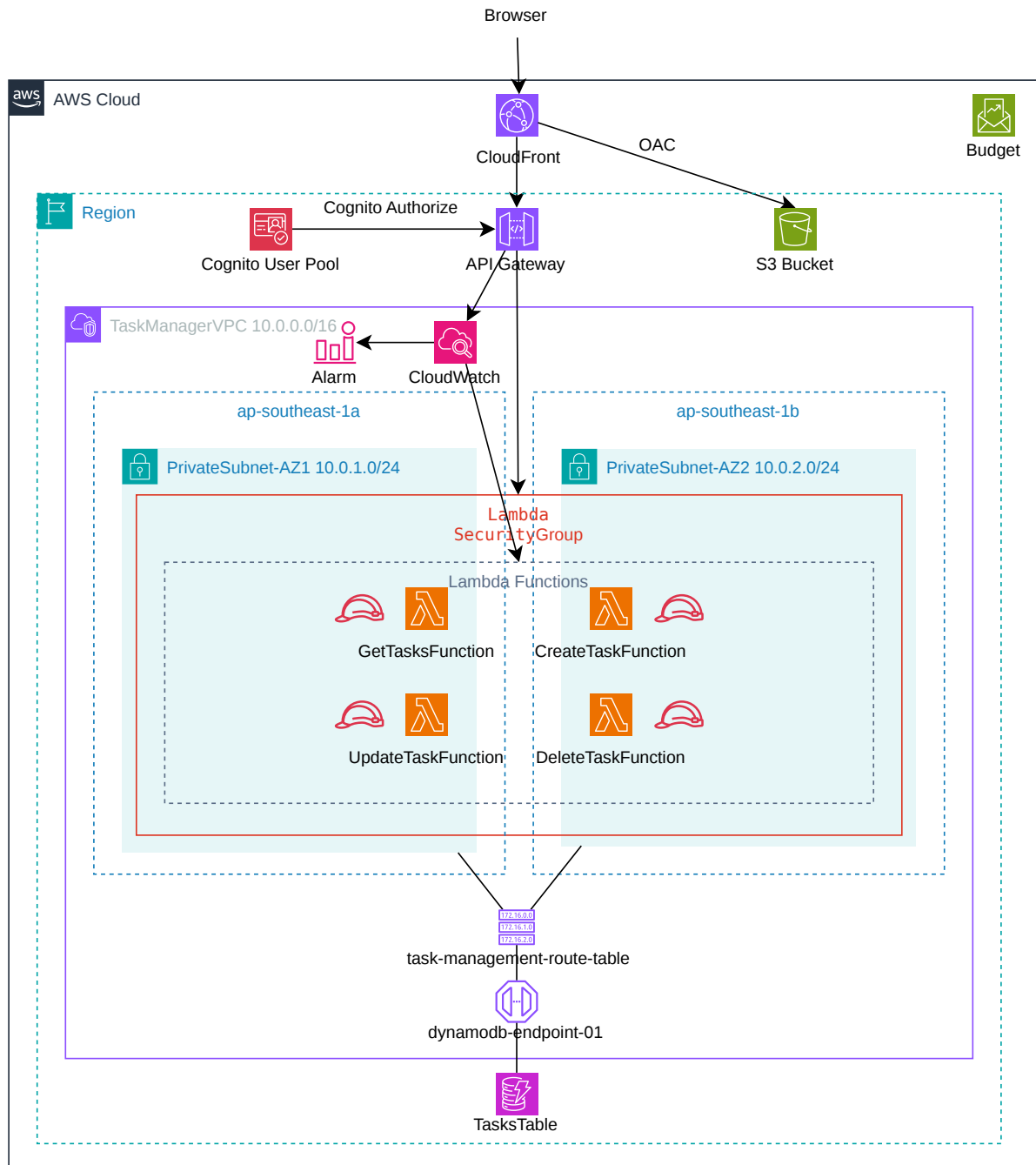
- Frontend được lưu trong S3 bucket riêng tư và chỉ được phục vụ qua CloudFront.
- CloudFront sử dụng Origin Access Control (OAC) để đọc object từ S3.
- Backend sử dụng API Gateway REST API stage `prod` và bốn Lambda function riêng biệt.
- Runtime của Lambda là Node.js 20.x.
- Lambda được đặt trong private subnet của custom VPC `TaskManagerVPC`.
- Lambda truy cập DynamoDB thông qua DynamoDB Gateway VPC Endpoint.
- API được bảo vệ bằng Cognito Authorizer.
- IAM được cấu hình theo nguyên tắc least privilege với bốn role riêng cho bốn Lambda function.
- CloudWatch Dashboard, CloudWatch Alarms, SNS và AWS Budget được cấu hình để giám sát và kiểm soát chi phí.

3 Thông tin endpoint

Thông tin	Giá trị
AWS Region	ap-southeast-1
CloudFront URL	https://d1ikfum6io2m2d.cloudfront.net/
API Gateway URL	https://x8hr2ow73f.execute-api.ap-southeast-1.amazonaws.com/prod/
S3 bucket frontend	https://taskmanager-ui-hieunguyen.s3.ap-southeast-1.amazonaws.com/index.html

Bảng 1: Thông tin triển khai thực tế của hệ thống

II Kiến trúc hệ thống



Hình 1: Sơ đồ kiến trúc serverless của ứng dụng Task Manager

1 Các thành phần chính

Thành phần	Vai trò
Amazon S3	Lưu trữ các file frontend. Bucket được đặt private, bật toàn bộ Block Public Access và không bật Static Website Hosting.
Amazon CloudFront	CDN duy nhất phục vụ frontend cho người dùng. CloudFront lấy file từ S3 thông qua OAC.
Origin Access Control	Cho phép CloudFront truy cập S3 private bucket một cách an toàn, không cần public bucket.
Amazon Cognito	Quản lý đăng ký, đăng nhập và phát hành JWT token cho frontend.
API Gateway REST API	Cung cấp HTTPS endpoint, định tuyến request đến Lambda, kiểm tra JWT bằng Cognito Authorizer và áp dụng throttling.
AWS Lambda	Chạy backend serverless bằng Node.js 20.x. Bốn Lambda function tách riêng tương ứng với bốn thao tác CRUD.
Amazon VPC	Cô lập tầng compute trong custom VPC TaskManagerVPC với hai private subnet.
DynamoDB Gateway Endpoint	Định tuyến traffic từ Lambda đến DynamoDB qua AWS private backbone, không cần NAT Gateway.
Amazon DynamoDB	Lưu trữ dữ liệu công việc trong bảng TasksTable , có GSI userId-index .
IAM	Cấp quyền least privilege bằng các role riêng cho từng Lambda function.
CloudWatch, SNS, AWS Budget	Giám sát metric, log, cảnh báo lỗi qua email và kiểm soát chi phí hàng tháng.

Bảng 2: Vai trò của các dịch vụ AWS trong hệ thống

2 Resource chính

Loại resource	Tên đã sử dụng
VPC	TaskManagerVPC
Private subnet AZ-1	PrivateSubnet-AZ1, CIDR 10.0.1.0/24, AZ ap-southeast-1a
Private subnet AZ-2	PrivateSubnet-AZ2, CIDR 10.0.2.0/24, AZ ap-southeast-1b
Security group	LambdaSecurityGroup
DynamoDB table	TasksTable
DynamoDB GSI	userId-index
Cognito User Pool	TaskManagerUserPool
Cognito App Client	WebAppClient
API Gateway REST API	TaskManagerAPI
CloudWatch Dashboard	TaskManager-Dashboard
AWS Budget	TaskManager-Budget-0.01

Bảng 3: Các resource chính của hệ thống

3 Luồng request

Khi người dùng mở ứng dụng, trình duyệt truy cập CloudFront domain. Nếu các file tĩnh như `index.html`, CSS và JavaScript đã có trong cache, CloudFront trả về trực tiếp từ edge location. Nếu cache miss, CloudFront lấy object từ S3 private bucket thông qua OAC. S3 bucket không public nên truy cập trực tiếp đến URL S3 sẽ bị từ chối.

Luồng tạo công việc sau khi người dùng đăng nhập:

1. Người dùng đăng nhập bằng Cognito và nhận JWT token.
2. Frontend gửi request HTTPS đến API Gateway endpoint `/tasks`, kèm header `Authorization`.
3. API Gateway dùng Cognito Authorizer để xác thực JWT token.
4. Nếu token hợp lệ, API Gateway gọi Lambda function tương ứng.
5. Lambda function chạy trong private subnet của `TaskManagerVPC`.
6. Lambda gửi request đến DynamoDB qua route table có destination là DynamoDB prefix list và target là VPC endpoint.

7. DynamoDB ghi hoặc đọc dữ liệu trong `TasksTable`.
8. Lambda trả JSON response về API Gateway, sau đó API Gateway trả kết quả về trình duyệt.

4 Tự mở rộng serverless

Hệ thống không cần Application Load Balancer vì API Gateway đã đóng vai trò entry point HTTPS và định tuyến request đến Lambda. Khi có nhiều request đồng thời, Lambda tự động tạo thêm execution environment để xử lý song song. Khi không có request, Lambda có thể giảm về không instance đang chạy, giúp giảm chi phí vận hành.

Để tránh runaway cost và bảo vệ giới hạn Free Tier, reserved concurrency được cấu hình như sau:

Lambda function	Reserved concurrency	Lý do
<code>GetTasksFunction</code>	5	Cho phép nhiều request đọc danh sách song song trong demo.
<code>CreateTaskFunction</code>	2	Giới hạn thao tác ghi mới để kiểm soát chi phí và lỗi lặp request.
<code>UpdateTaskFunction</code>	2	Đủ cho demo cập nhật đồng thời, vẫn giới hạn mức ghi.
<code>DeleteTaskFunction</code>	1	Xóa task là thao tác ít dùng hơn và nên được giới hạn chặt.

Bảng 4: Reserved concurrency của các Lambda function

Nếu reserved concurrency đặt quá thấp, người dùng có thể gặp throttling dù hệ thống vẫn còn khả năng xử lý. Nếu đặt quá cao, lỗi vòng lặp hoặc lượng request bất thường có thể tạo nhiều invocation và làm tăng chi phí.

5 CDN và Origin Access Control

CloudFront giúp giảm độ trễ bằng cách cache static assets tại edge location gần người dùng. Khi cache hit, CloudFront trả nội dung mà không cần truy cập lại S3. Khi cache miss, CloudFront lấy nội dung từ origin là S3 bucket.

S3 bucket bắt buộc private vì frontend không được truy cập qua URL S3 trực tiếp. Origin Access Control là cơ chế cho phép CloudFront ký request đến S3 và bucket policy chỉ cho phép CloudFront

service principal đọc object từ distribution hợp lệ. Nhờ đó, CloudFront là public entry point duy nhất của frontend.

6 VPC Endpoint

Lambda được gắn VpcConfig vào hai private subnet để backend chạy trong mạng riêng. Vì private subnet không có NAT Gateway, Lambda không thể gọi DynamoDB qua internet công cộng. DynamoDB Gateway Endpoint giải quyết vấn đề này bằng cách thêm route đến DynamoDB prefix list trong route table của private subnet.

Traffic từ Lambda đến DynamoDB đi qua AWS private backbone theo đường: Lambda trong private subnet → route table → DynamoDB Gateway Endpoint → DynamoDB. Cách này an toàn hơn và không phát sinh chi phí cố định như NAT Gateway.

III Kết quả và bằng chứng

1 Bằng chứng bảo mật frontend

ID	Bằng chứng	File hình/output
SE-1	S3 Block Public Access bật cả bốn tùy chọn.	TODO
SE-2	Truy cập trực tiếp S3 URL trả về 403 Forbidden hoặc AccessDenied .	TODO
SE-3	Truy cập CloudFront URL thành công với 200 OK.	TODO
SE-4	CloudFront distribution có Origin Access Control.	TODO

Bảng 5: Bằng chứng bảo mật frontend

2 Bằng chứng Cognito và API security

ID	Bằng chứng	File hình/output
CO-1	Cognito User Pool TaskManagerUserPool đã tạo.	TODO
CO-2	API Gateway Cognito Authorizer đã cấu hình.	TODO
CO-3	Gọi API không có token trả về 401 Unauthorized .	TODO
CO-4	Gọi API với token hợp lệ trả về 200 OK.	TODO

Bảng 6: Bằng chứng Cognito và API security

3 Bằng chứng networking

ID	Bằng chứng	File hình/output
NE-1	DynamoDB Gateway Endpoint có status <code>Available</code> .	TODO
NE-2	Lambda có VpcConfig với private subnets và security group.	TODO
NE-3	Route table có dòng <code>pl-xxxxxx -> vpce-xxxxxxx</code> .	TODO
NE-4	Không có NAT Gateway đang hoạt động.	TODO
NE-5	CloudWatch log cho thấy Lambda gọi DynamoDB thành công.	TODO

Bảng 7: Bằng chứng networking

4 Bằng chứng IAM

ID	Bằng chứng	File hình/output
IM-1	Bốn IAM role riêng: <code>GetTasksLambdaRole</code> , <code>CreateTaskLambdaRole</code> , <code>UpdateTaskLambdaRole</code> , <code>DeleteTaskLambdaRole</code> .	TODO
IM-2	Policy JSON dùng ARN cụ thể của <code>TasksTable</code> và <code>userId-index</code> , không dùng resource <code>*</code> .	TODO
IM-3	Mỗi Lambda function gắn đúng IAM role tương ứng.	TODO

Bảng 8: Bằng chứng IAM

5 Giám sát

CloudWatch Dashboard `TaskManager-Dashboard` đã được tạo với ít nhất năm widget có dữ liệu thực. Hai alarm `Lambda-Error-Alarm` và `API-5xx-Alarm` gửi thông báo qua SNS email subscription.

Mục	Yêu cầu	Bằng chứng
CloudWatch Dashboard	Tối thiểu 5 widget có dữ liệu thực.	TODO
Lambda-Error-Alarm	Errors lớn hơn 10 trong 5 phút.	TODO
API-5xx-Alarm	5XXError lớn hơn 5 trong 5 phút.	TODO
Log request thành công	Có REPORT, status 200, duration, billed duration, memory used.	TODO
Log request lỗi	Có lỗi validation hoặc stack trace khi input không hợp lệ.	TODO

Bảng 9: Bảng chứng monitoring và logging

6 Chi phí

Kiến trúc được thiết kế để giữ chi phí gần bằng 0:

- Không sử dụng EC2.
- Không tạo NAT Gateway.
- Lambda có reserved concurrency để giới hạn invocation bất thường.
- API Gateway có throttling rate 100 request/giây và burst 50.
- DynamoDB dùng bảng và GSI trong phạm vi demo nhỏ.
- AWS Budget giới hạn 0.01 USD/tháng với cảnh báo 80% và 100%.

Mục	Giá trị	Bằng chứng
Budget name	TaskManager-Budget-0.01	TODO
Monthly budget	0.01 USD	TODO
Alert 80%	0.008 USD	TODO
Alert 100%	0.01 USD	TODO
Actual cost	TODO: điền chi phí thực tế từ Billing Dashboard hoặc Cost Explorer	TODO

Bảng 10: Bảng chứng kiểm soát chi phí

A Phụ lục

1 Checklist bằng chứng bắt buộc

ID	Bằng chứng	Đã có
SE-1	S3 Block Public Access bật cả bốn tùy chọn.	TODO
SE-2	Direct S3 access trả về 403 Forbidden.	TODO
SE-3	CloudFront access trả về 200 OK.	TODO
SE-4	OAC gắn vào CloudFront distribution.	TODO
CO-1	Cognito User Pool đã tạo.	TODO
CO-2	API Gateway Cognito Authorizer được cấu hình.	TODO
CO-3	API không có token trả về 401 Unauthorized.	TODO
CO-4	API có token hợp lệ trả về 200 OK.	TODO
NE-1	DynamoDB VPC Endpoint status Available.	TODO
NE-2	Lambda VpcConfig có private subnets và security group.	TODO
NE-3	Route table có route <code>pl-xxxxxx -> vpce-xxxxxxxx</code> .	TODO
NE-4	Không có NAT Gateway đang hoạt động.	TODO
NE-5	CloudWatch log cho thấy Lambda gọi DynamoDB thành công.	TODO
IM-1	Bốn IAM role riêng cho bốn Lambda function.	TODO
IM-2	IAM policy dùng ARN cụ thể của DynamoDB table/index, không dùng resource *.	TODO
IM-3	Mỗi Lambda function gắn đúng role tương ứng.	TODO

Bảng 11: Checklist bằng chứng SE/CO/NE/IM

2 Prompt GenAI

Vì nhóm có sử dụng GenAI để hỗ trợ lập dàn ý và viết báo cáo, cần nộp kèm lịch sử prompt hoặc screenshot đoạn hội thoại theo yêu cầu đồ án.

- TODO: Chèn hoặc đính kèm lịch sử prompt đã sử dụng.
- TODO: Chèn screenshot hội thoại nếu nộp dưới dạng hình ảnh.

3 Ghi chú source code

Source code cần nộp kèm gồm:

- Frontend: HTML, CSS, JavaScript.
- Backend: mã Node.js 20.x cho bốn Lambda handler.
- README mô tả cách chạy local và cách deploy lên AWS.

Không có source code IaC vì hạ tầng được triển khai thủ công bằng AWS Console.